Foglio di lavoro sulla fuga di dati

Riepilogo dell'incidente: durante una riunione, un responsabile vendite ha dato al suo team accesso a una cartella di documenti riservati all'uso interno. La cartella conteneva file legati a un nuovo prodotto non ancora annunciato, oltre ad analisi sui clienti e materiali promozionali. Dopo la riunione il responsabile non ha tolto l'accesso alla cartella, ma ha avvisato il team di aspettare l'approvazione prima di condividere i materiali promozionali con altri.

Durante una videochiamata con un partner commerciale, un membro del team vendite ha dimenticato l'avviso del responsabile. Voleva condividere il link ai materiali promozionali, perché il partner li diffondesse ai suoi clienti, ma per errore ha mandato il link alla cartella interna. Più tardi il partner ha pubblicato il link sulla pagina social della sua azienda, convinto che fossero i materiali promozionali.

Controllo	**Privilegio minimo**
Problemi	*Quali fattori hanno contribuito alla fuga di informazioni?* *Sono andate storte più cose insieme. Il responsabile ha lasciato aperta tutta la cartella interna dopo la riunione, anche se al team servivano solo i file promozionali, e nella cartella c'erano anche il prodotto non annunciato e le analisi sui clienti. L'unica protezione era un avviso a voce. Le impostazioni di condivisione permettevano inoltre di mandare il link alla cartella anche a persone esterne all'azienda. Il rappresentante vendite ha scelto per errore il link sbagliato, e il partner lo ha pubblicato senza controllare cosa fosse.*
Verifica	*Di cosa si occupa NIST SP 800-53: AC-6?* *AC-6 è il controllo sul privilegio minimo. Dice che gli utenti devono ricevere solo l'accesso e l'autorizzazione minimi che servono a svolgere il loro compito, e nulla di più. Account, ruoli e processi vanno impostati in modo che nessuno lavori con privilegi più alti del necessario.*
Raccomandazioni	*Come si potrebbe migliorare il principio del privilegio minimo in azienda?*

	L'accesso alla cartella dovrebbe dipendere dal ruolo. I materiali promozionali dovrebbero stare in una cartella separata, sicura da condividere, e la cartella interna dovrebbe restare limitata a chi ne ha bisogno. L'accesso dato per una riunione dovrebbe scadere alla fine della riunione, oppure essere tolto dal responsabile subito dopo. I link ai file interni dovrebbero funzionare solo con account aziendali, e condividere con persone esterne dovrebbe richiedere un'approvazione. Aiuterebbero anche controlli regolari su chi può aprire cosa e una breve formazione sulla condivisione dei link.
Motivazione	*In che modo questi miglioramenti risolvono i problemi?* *Una cartella separata per il materiale pubblico fa sì che un clic sbagliato condivida qualcosa di innocuo. La scadenza automatica elimina il problema del responsabile che dimentica di togliere l'accesso. Bloccare i link per gli utenti esterni avrebbe fermato la fuga anche dopo l'errore, mentre i controlli periodici e la formazione riducono la probabilità che succeda di nuovo.*

Quadro del piano di sicurezza

Il NIST Cybersecurity Framework (CSF) organizza le informazioni in una struttura gerarchica ad albero. Da sinistra a destra descrive una funzione di sicurezza generale, poi diventa più specifico passando a una categoria, una sottocategoria e ai singoli controlli di sicurezza.

Funzione	Categoria	Sottocategoria	Riferimenti
Proteggere	PR.DS: sicurezza dei dati	PR.DS-5: protezioni contro le fughe di dati.	NIST SP 800-53: AC-6

In questo esempio, i controlli usati dal produttore per proteggersi dalle fughe di dati sono definiti in NIST SP 800-53, un insieme di linee guida per proteggere la privacy dei sistemi informativi.

Nota: i riferimenti sono spesso collegati con un link alle linee guida o alle norme a cui si riferiscono. Questo rende facile approfondire come va attuato un certo controllo. È comune trovare più link a fonti diverse nelle colonne dei riferimenti.

NIST SP 800-53: AC-6

NIST ha sviluppato SP 800-53 per dare alle aziende un piano personalizzabile sulla privacy delle informazioni. È una risorsa completa che descrive molte categorie di controlli. Ogni controllo fornisce alcune informazioni chiave:

- **Controllo: la definizione del controllo di sicurezza.**
- **Discussione: la descrizione di come il controllo dovrebbe essere attuato.**
- **Miglioramenti del controllo: un elenco di suggerimenti per renderlo più efficace.**

AC-6	**Privilegio minimo**
	Controllo: Agli utenti si dovrebbero dare solo l'accesso e l'autorizzazione minimi necessari per completare un compito o una funzione.
	Discussione: Processi, account utente e ruoli vanno applicati come serve per ottenere il privilegio minimo. L'obiettivo è impedire a un utente di operare con livelli di privilegio più alti di quelli necessari per svolgere le sue attività.
	Miglioramenti del controllo: ● Limitare l'accesso alle risorse sensibili in base al ruolo dell'utente. ● Revocare automaticamente l'accesso alle informazioni dopo un certo periodo. ● Conservare i log delle attività degli account utente creati. ● Controllare regolarmente i privilegi degli utenti.

Nota: nella categoria dei controlli di accesso, SP 800-53 mette il privilegio minimo al sesto posto, cioè AC-6.